

Web Application Report

This report includes important security information about your web application.

OWASP Top 10 2021 report

This report was created by HCL AppScan Standard 10.10.1
Scan started: 5/4/2026 1:45:37 PM

Scan Summary

Test policy: Default
CVSS version: 3.1
Scanned pages: 12
Security entities tested: 253
Compliance issues found: 65

Regulations

OWASP Top Ten 2021 – The Ten Most Critical Web Application Security Risks

Summary Description

The goal of the Top 10 project is to raise awareness about application security by identifying some of the most critical risks facing organizations. Development projects should address these potential risks in their requirements documents and design, build and test their applications to ensure that they have taken the necessary measures to reduce these risks to the minimum. Project managers should include time and budget for application security activities including developer training, application security policy development, security mechanism design and development, penetration testing, and security code review as part over the overall effort to address the risks.

The primary aim of the OWASP Top 10 is to educate developers, designers, architects, managers, and organizations about the consequences of the most important web application security risks. The Top 10 provides basic guidance on how to address against these risks and where to go to learn more on how to address them.

Although set out as an education piece, rather than a standard or a regulation, it is important to note that several prominent industry and government regulators are referencing the OWASP top ten. These bodies include among others VISA USA, MasterCard International and the American Federal Trade Commission (FTC).

However, according to the OWASP team the OWASP top ten first and foremost an education piece, not a standard. The OWASP team suggests that any organization about to adopt the Top Ten paper as a policy or standard to consult with the OWASP team first.

What Changed From 2017 to 2021?

A01:2021-Broken Access Control moves up from the fifth position to the category with the most serious web application security risk; the contributed data indicates that on average, 3.81% of applications tested had one or more Common Weakness Enumerations (CWEs) with more than 318k occurrences of CWEs in this risk category. The 34 CWEs mapped to Broken Access Control had more occurrences in applications than any other category.

A02:2021-Cryptographic Failures shifts up one position to #2, previously known as A3:2017-Sensitive Data Exposure, which was broad symptom rather than a root cause. The renewed name focuses on failures related to cryptography as it has been implicitly before. This category often leads to sensitive data exposure or system compromise.

A03:2021-Injection slides down to the third position. 94% of the applications were tested for some form of injection with a max incidence rate of 19%, an average incidence rate of 3.37%, and the 33 CWEs mapped into this category have the second most occurrences in applications with 274k occurrences. Cross-site Scripting is now part of this category in this edition.

A04:2021-Insecure Design is a new category for 2021, with a focus on risks related to design flaws. If we genuinely want to "move left" as an industry, we need more threat modeling, secure design patterns and principles, and reference architectures. An insecure design cannot be fixed by a perfect implementation as by definition, needed security controls were never created to defend against specific attacks.

A05:2021-Security Misconfiguration moves up from #6 in the previous edition; 90% of applications were tested for some form of misconfiguration, with an average incidence rate of 4.5%, and over 208k occurrences of CWEs mapped to this risk category. With more shifts into highly configurable software, it's not surprising to see this category move up. The former category for A4:2017-XML External Entities (XXE) is now part of this risk category.

A06:2021-Vulnerable and Outdated Components was previously titled Using Components with Known Vulnerabilities and is #2 in the Top 10 community survey, but also had

enough data to make the Top 10 via data analysis. This category moves up from #9 in 2017 and is a known issue that we struggle to test and assess risk. It is the only category not to have any Common Vulnerability and Exposures (CVEs) mapped to the included CWEs, so a default exploit and impact weights of 5.0 are factored into their scores.

A07:2021-Identification and Authentication Failures was previously Broken Authentication and is sliding down from the second position, and now includes CWEs that are more related to identification failures. This category is still an integral part of the Top 10, but the increased availability of standardized frameworks seems to be helping.

A08:2021-Software and Data Integrity Failures is a new category for 2021, focusing on making assumptions related to software updates, critical data, and CI/CD pipelines without verifying integrity. One of the highest weighted impacts from Common Vulnerability and Exposures/Common Vulnerability Scoring System (CVE/CVSS) data mapped to the 10 CWEs in this category. A8:2017-Insecure Deserialization is now a part of this larger category.

A09:2021-Security Logging and Monitoring Failures was previously A10:2017-Insufficient Logging & Monitoring and is added from the Top 10 community survey (#3), moving up from #10 previously. This category is expanded to include more types of failures, is challenging to test for, and isn't well represented in the CVE/CVSS data. However, failures in this category can directly impact visibility, incident alerting, and forensics.

A10:2021-Server-Side Request Forgery is added from the Top 10 community survey (#1). The data shows a relatively low incidence rate with above average testing coverage, along with above-average ratings for Exploit and Impact potential. This category represents the scenario where the security community members are telling us this is important, even though it's not illustrated in the data at this time.

Covered Entities

All companies and other entities that develop any kind of web application code are encouraged to address the top ten list as part of their overall security risk management. Adopting the OWASP Top Ten is an effective first step towards changing the software development culture within the organization into one that produces secure code.

For more information on OWASP Top Ten, please review the - OWASP Top Ten 2021 – The Ten Most Critical Web Application Security Risks, at <https://owasp.org/Top10/>

For more information on securing web applications, please visit <https://www.hcltechsw.com/appscan>

The information provided does not constitute legal advice. The results of a vulnerability assessment will demonstrate potential vulnerabilities in your application that should be corrected in order to reduce the likelihood that your information will be compromised. As legal advice must be tailored to the specific application of each law, and laws are constantly changing, nothing provided herein should be used as a substitute for the advice of competent counsel. HCL customers are responsible for ensuring their own compliance with legal requirements. It is the customer's sole responsibility to obtain advice of competent legal counsel as to the identification and interpretation of any relevant laws and regulatory requirements that may affect the customer's business and any actions the customer may need to take to comply with such laws.

Violated Section

Issues detected across 5/10 sections of the regulation:

Sections	Number of Issues
A1 - Broken Access Control	43
A2 - Cryptographic Failures	0
A3 - Injection	22
A4 - Insecure Design	33
A5 - Security Misconfiguration	20
A6 - Vulnerable and Outdated Components	0
A7 - Identification and Authentication Failures	0
A8 - Software and Data Integrity Failures	20
A9 - Security Logging and Monitoring Failures	0
A10 - Server-Side Request Forgery (SSRF)	0

Section Violation By Issue

65 Unique issues detected across 5/10 sections of the regulation:

URL	Entity	Issue Type	Sections
https://qa.gmsgetb.kpmglinkgo.com/	qa.gmsgetb.kpmglinkgo.com	Mssing or insecure Cross-Origin-Resource-Policy (CORP) header	A1
https://qa.gmsgetb.kpmglinkgo.com/	qa.gmsgetb.kpmglinkgo.com	Mssing or insecure Cross-Origin-Opener-Policy (COOP) header	A1

https://qa.gmsgetb.kpmglinkgo.com/	TC-BAC-DEV	Cookie with SameSite attribute not Restrictive	A1
https://qa.gmsgetb.kpmglinkgo.com/	qa.gmsgetb.kpmglinkgo.com	Missing or insecure Cross-Origin-Embedder-Policy (COEP) header	A1
https://qa.gmsgetb.kpmglinkgo.com/	.mysql_history/	Hidden Directory Detected	A1
https://qa.gmsgetb.kpmglinkgo.com/gettaxcalcbac/login/enter	enter	Trusted types in scripts not enforced in CSP	A3, A4, A5, A8
https://qa.gmsgetb.kpmglinkgo.com/	qa.gmsgetb.kpmglinkgo.com	Missing "Referrer policy" Security Header	A1
https://qa.gmsgetb.kpmglinkgo.com/gettaxcalcbac/login/enter	enter	Directives ignored by browsers found in CSP	A3, A4, A5, A8
https://qa.gmsgetb.kpmglinkgo.com/	OpenIdConnect.nonce.gZZ5PEnNZa%2BVjN5fWYMKrbfOPOeoVN7TsO1QpcMf%3D	Cookie with Insecure or Improper or Missing SameSite attribute	A1
https://qa.gmsgetb.kpmglinkgo.com/gettaxcalcbac/login/index/	index/	Hidden Directory Detected	A1
https://qa.gmsgetb.kpmglinkgo.com/gettaxcalcbac/login/	login/	Hidden Directory Detected	A1
https://qa.gmsgetb.kpmglinkgo.com/gettaxcalcbac/login/.profile/	.profile/	Hidden Directory Detected	A1
https://qa.gmsgetb.kpmglinkgo.com/.profile/	.profile/	Hidden Directory Detected	A1
https://qa.gmsgetb.kpmglinkgo.com/gettaxcalcbac/.profile/	.profile/	Hidden Directory Detected	A1
https://qa.gmsgetb.kpmglinkgo.com/gettaxcalcbac/login/.sh_history/	.sh_history/	Hidden Directory Detected	A1
https://qa.gmsgetb.kpmglinkgo.com/gettaxcalcbac/login/.svn/	.svn/	Hidden Directory Detected	A1
https://qa.gmsgetb.kpmglinkgo.com/gettaxcalcbac/.sh_history/	.sh_history/	Hidden Directory Detected	A1
https://qa.gmsgetb.kpmglinkgo.com/.sh_history/	.sh_history/	Hidden Directory Detected	A1
https://qa.gmsgetb.kpmglinkgo.com/gettaxcalcbac/.svn/	.svn/	Hidden Directory Detected	A1
https://qa.gmsgetb.kpmglinkgo.com/.svn/	.svn/	Hidden Directory Detected	A1
https://qa.gmsgetb.kpmglinkgo.com/gettaxcalcbac/login/.bashrc/	.bashrc/	Hidden Directory Detected	A1
https://qa.gmsgetb.kpmglinkgo.com/.bashrc/	.bashrc/	Hidden Directory Detected	A1
https://qa.gmsgetb.kpmglinkgo.com/gettaxcalcbac/.bashrc/	.bashrc/	Hidden Directory Detected	A1
https://qa.gmsgetb.kpmglinkgo.com/gettaxcalcbac/login/.git/	.git/	Hidden Directory Detected	A1
https://qa.gmsgetb.kpmglinkgo.com/.git/	.git/	Hidden Directory Detected	A1
https://qa.gmsgetb.kpmglinkgo.com/gettaxcalcbac/login/.mysql_history/	.mysql_history/	Hidden Directory Detected	A1
https://qa.gmsgetb.kpmglinkgo.com/gettaxcalcbac/.git/	.git/	Hidden Directory Detected	A1
https://qa.gmsgetb.kpmglinkgo.com/gettaxcalcbac/.mysql_history/	.mysql_history/	Hidden Directory Detected	A1
https://qa.gmsgetb.kpmglinkgo.com/gettaxcalcbac/login/enter	enter	Required directives missing from the CSP	A3, A4, A5, A8
https://qa.gmsgetb.kpmglinkgo.com/gettaxcalcbac/login/index/		Directives ignored by browsers found in CSP	A3, A4, A5, A8
https://qa.gmsgetb.kpmglinkgo.com/gettaxcalcbac/login/index/		Trusted types in scripts not enforced in CSP	A3, A4, A5, A8
https://qa.gmsgetb.kpmglinkgo.com/gettaxcalcbac/javascript/calendar-setup.js	calendar-setup.js	Cacheable SSL Page Found	A1, A4
https://qa.gmsgetb.kpmglinkgo.com/gettaxcalcbac/javascript/fingerprint2.js	fingerprint2.js	Email Address Pattern Found	A1, A4
https://qa.gmsgetb.kpmglinkgo.com/gettaxcalcbac/javascript/calendar.js	calendar.js	Cacheable SSL Page Found	A1, A4
https://qa.gmsgetb.kpmglinkgo.com/gettaxcalcbac/javascript/navResizer.js	navResizer.js	Cacheable SSL Page Found	A1, A4
https://qa.gmsgetb.kpmglinkgo.com/gettaxcalcbac/login/index/		Required directives missing from the CSP	A3, A4, A5, A8
https://qa.gmsgetb.kpmglinkgo.com/gettaxcalcbac/javascript/target[	target[	Trusted types in scripts not enforced in CSP	A3, A4, A5, A8
https://qa.gmsgetb.kpmglinkgo.com/gettaxcalcbac/Home/QuickSearch	QuickSearch	Directives ignored by browsers found in CSP	A3, A4, A5, A8
https://qa.gmsgetb.kpmglinkgo.com/gettaxcalcbac/Home/QuickSearch	QuickSearch	Body Parameters Accepted in Query	A1
https://qa.gmsgetb.kpmglinkgo.com/gettaxcalcbac/		Directives ignored by browsers found in CSP	A3, A4, A5, A8
https://qa.gmsgetb.kpmglinkgo.com/gettaxcalcbac/javascript/target[	target[	Directives ignored by browsers found in CSP	A3, A4, A5, A8
https://qa.gmsgetb.kpmglinkgo.com/gettaxcalcbac/Home/QuickSearch	QuickSearch	Trusted types in scripts not enforced in CSP	A3, A4, A5, A8
https://qa.gmsgetb.kpmglinkgo.com/gettaxcalcbac/login/index/		Body Parameters Accepted in Query	A1

https://qa.gmsgetb.kpmglinkgo.com/gettaxcalcbac/javascript/backgroundtasks.js	backgroundtasks.js	Cacheable SSL Page Found	A1, A4
https://qa.gmsgetb.kpmglinkgo.com/gettaxcalcbac/javascript/commonFunctions.js	commonFunctions.js	Cacheable SSL Page Found	A1, A4
https://qa.gmsgetb.kpmglinkgo.com/gettaxcalcbac/javascript/site.js	site.js	Cacheable SSL Page Found	A1, A4
https://qa.gmsgetb.kpmglinkgo.com/gettaxcalcbac/javascript/popupWindow.js	popupWindow.js	Cacheable SSL Page Found	A1, A4
https://qa.gmsgetb.kpmglinkgo.com/gettaxcalcbac/javascript/views/help.js	help.js	Cacheable SSL Page Found	A1, A4
https://qa.gmsgetb.kpmglinkgo.com/gettaxcalcbac/javascript/views/auditLog.js	auditLog.js	Cacheable SSL Page Found	A1, A4
https://qa.gmsgetb.kpmglinkgo.com/gettaxcalcbac/javascript/views/adminVariable.js	adminVariable.js	Cacheable SSL Page Found	A1, A4
https://qa.gmsgetb.kpmglinkgo.com/gettaxcalcbac/Home/QuickSearch	QuickSearch	Required directives missing from the CSP	A3, A4, A5, A8
https://qa.gmsgetb.kpmglinkgo.com/gettaxcalcbac/SiteException	SiteException	Body Parameters Accepted in Query	A1
https://qa.gmsgetb.kpmglinkgo.com/gettaxcalcbac/		Required directives missing from the CSP	A3, A4, A5, A8
https://qa.gmsgetb.kpmglinkgo.com/gettaxcalcbac/javascript/target[target[	target[	Inline script execution allowed in CSP	A3, A4, A5, A8
https://qa.gmsgetb.kpmglinkgo.com/gettaxcalcbac/javascript/target[target[	target[	Required directives missing from the CSP	A3, A4, A5, A8
https://qa.gmsgetb.kpmglinkgo.com/gettaxcalcbac/SiteException	SiteException	Trusted types in scripts not enforced in CSP	A3, A4, A5, A8
https://qa.gmsgetb.kpmglinkgo.com/gettaxcalcbac/javascript/locationUtils.js	locationUtils.js	Cacheable SSL Page Found	A1, A4
https://qa.gmsgetb.kpmglinkgo.com/gettaxcalcbac/login/index/	txtAdditionalArg	Blind LDAP Injection	A3
https://qa.gmsgetb.kpmglinkgo.com/gettaxcalcbac/javascript/appMaster.js	appMaster.js	Cacheable SSL Page Found	A1, A4
https://qa.gmsgetb.kpmglinkgo.com/gettaxcalcbac/javascript/appMaster.js	appMaster.js	Web Application Source Code Disclosure Pattern Found	A1
https://qa.gmsgetb.kpmglinkgo.com/gettaxcalcbac/		Trusted types in scripts not enforced in CSP	A3, A4, A5, A8
https://qa.gmsgetb.kpmglinkgo.com/gettaxcalcbac/SiteException	SiteException	Directives ignored by browsers found in CSP	A3, A4, A5, A8
https://qa.gmsgetb.kpmglinkgo.com/gettaxcalcbac/SiteException	SiteException	Required directives missing from the CSP	A3, A4, A5, A8
https://qa.gmsgetb.kpmglinkgo.com/gettaxcalcbac/Home/QuickSearch	userLogin	Blind LDAP Injection	A3
https://qa.gmsgetb.kpmglinkgo.com/	qa.gmsgetb.kpmglinkgo.com	Missing "Content-Security-Policy" header	A3, A4, A5, A8

Detailed Security Issues by Sections

M

A1 - Broken Access Control 43

Cookie with Insecure or Improper or Missing SameSite attribute

Risk:	Prevent cookie information leakage by restricting cookies to first-party or same-site context, Attacks can extend to Cross-Site-Request-Forgery (CSRF) attacks if there are no additional protections in place (such as Anti-CSRF tokens).
Cause:	Sensitive Cookie with Improper or Insecure or Missing SameSite Attribute
Fix:	Review possible solutions for configuring SameSite Cookie attribute to recommended values
CVSS Score:	4.7
CVSS Vector:	AV:N/AC:L/PR:L/UI:N/S:U/C:L/I:L/A:N/E:U/RL:O/RC:C/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MJI:X/MS:X/MC:X/MI:X/MA:X

Severity	URL	Entity
Medium	https://qa.gmsgetb.kpmglinkgo.com/	OpenIdConnect.nonce.gZz5PEnNZaA%2BVjN5fWWMkrblfOPOeovN7TsO1QpcM/%3D

Missing or insecure Cross-Origin-Embedder-Policy (COEP) header

Risk:	It is possible to gather sensitive information about the web application such as usernames, passwords, machine name and/or sensitive file locations
Cause:	Insecure web application programming or configuration
Fix:	Add or modify the "Cross-Origin-Embedder-Policy" (COEP) header to "require-corp"
CVSS Score:	4.2
CVSS Vector:	AV:N/AC:H/PR:N/UI:R/S:U/C:L/I:L/A:N/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MJI:X/MS:X/MC:X/MI:X/MA:X

Severity	URL	Entity
Medium	https://qa.gmsgetb.kpmglinkgo.com/	qa.gmsgetb.kpmglinkgo.com

Missing or insecure Cross-Origin-Opener-Policy (COOP) header

Risk:	It is possible to gather sensitive information about the web application such as usernames, passwords, machine name and/or sensitive file locations
Cause:	Insecure web application programming or configuration
Fix:	Add or modify the "Cross-Origin-Opener-Policy" (COOP) header to "same-origin"
CVSS Score:	4.8
CVSS Vector:	AV:N/AC:H/PR:N/UI:N/S:U/C:L/I:L/A:N/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MJI:X/MS:X/MC:X/MI:X/MA:X

Severity	URL	Entity
Medium	https://qa.gmsgetb.kpmglinkgo.com/	qa.gmsgetb.kpmglinkgo.com

Missing or insecure Cross-Origin-Resource-Policy (CORP) header

Risk:	It is possible to gather sensitive information about the web application such as usernames, passwords, machine name and/or sensitive file locations
Cause:	Insecure web application programming or configuration
Fix:	Add or modify the "Cross-Origin-Resource-Policy" (CORP) header to "same-origin" or "same-site"
CVSS Score:	4.8
CVSS Vector:	AV:N/AC:H/PR:N/UI:N/S:U/C:L/I:L/A:N/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MJI:X/MS:X/MC:X/MI:X/MA:X

Severity	URL	Entity
Medium	https://qa.gmsgetb.kpmglinkgo.com/	qa.gmsgetb.kpmglinkgo.com

Body Parameters Accepted in Query

Risk: It is possible to gather sensitive information about the web application such as usernames, passwords, machine name and/or sensitive file locations
It is possible to persuade a naive user to supply sensitive information such as username, password, credit card number, social security number etc.

Cause: Insecure web application programming or configuration

Fix: Do not accept body parameters that are sent in the query string

CVSS Score: 3.7

CVSS Vector: AV:N/AC:H/PR:N/UI:N/S:U/C:L/I:N/A:N/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MUI:X/MS:X/MC:X/MI:X/MA:X

Severity	URL	Entity
Low	https://qa.gmsgetb.kpmglinkgo.com/gettaxcalcbac/Home/QuickSearch	QuickSearch
Low	https://qa.gmsgetb.kpmglinkgo.com/gettaxcalcbac/login/index/	
Low	https://qa.gmsgetb.kpmglinkgo.com/gettaxcalcbac/SiteException	SiteException

Cacheable SSL Page Found

Risk: It is possible to gather sensitive information about the web application such as usernames, passwords, machine name and/or sensitive file locations

Cause: Sensitive information might have been cached by your browser

Fix: Prevent caching of SSL pages by adding "Cache-Control: no-store" and "Pragma: no-cache" headers to their responses.

CVSS Score: 3.7

CVSS Vector: AV:N/AC:H/PR:N/UI:N/S:U/C:L/I:N/A:N/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MUI:X/MS:X/MC:X/MI:X/MA:X

Severity	URL	Entity
Low	https://qa.gmsgetb.kpmglinkgo.com/gettaxcalcbac/javascript/calendar-setup.js	calendar-setup.js
Low	https://qa.gmsgetb.kpmglinkgo.com/gettaxcalcbac/javascript/calendar.js	calendar.js
Low	https://qa.gmsgetb.kpmglinkgo.com/gettaxcalcbac/javascript/navResizer.js	navResizer.js
Low	https://qa.gmsgetb.kpmglinkgo.com/gettaxcalcbac/javascript/backgroundtasks.js	backgroundtasks.js
Low	https://qa.gmsgetb.kpmglinkgo.com/gettaxcalcbac/javascript/commonFunctions.js	commonFunctions.js
Low	https://qa.gmsgetb.kpmglinkgo.com/gettaxcalcbac/javascript/site.js	site.js
Low	https://qa.gmsgetb.kpmglinkgo.com/gettaxcalcbac/javascript/popupWindow.js	popupWindow.js
Low	https://qa.gmsgetb.kpmglinkgo.com/gettaxcalcbac/javascript/views/help.js	help.js
Low	https://qa.gmsgetb.kpmglinkgo.com/gettaxcalcbac/javascript/views/auditLog.js	auditLog.js
Low	https://qa.gmsgetb.kpmglinkgo.com/gettaxcalcbac/javascript/views/adminVariable.js	adminVariable.js
Low	https://qa.gmsgetb.kpmglinkgo.com/gettaxcalcbac/javascript/locationUtils.js	locationUtils.js
Low	https://qa.gmsgetb.kpmglinkgo.com/gettaxcalcbac/javascript/appMaster.js	appMaster.js

Hidden Directory Detected

Risk:	It is possible to retrieve information about the site's file system structure, which may help the attacker to map the web site
Cause:	The web server or application server are configured in an insecure way
Fix:	Issue a "404 - Not Found" response status code for a forbidden resource, or remove it completely
CVSS Score:	3.7
CVSS Vector:	AV:N/AC:H/PR:N/UI:N/S:U/C:L/I:N/A:N/E:X/RL:X/RC:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MUI:X/MS:X/MC:X/MI:X/MA:X

Severity	URL	Entity
Low	https://qa.gmsgetb.kpmglinkgo.com/	.mysql_history/
Low	https://qa.gmsgetb.kpmglinkgo.com/gettaxcalcbac/login/	index/
Low	https://qa.gmsgetb.kpmglinkgo.com/gettaxcalcbac/	login/
Low	https://qa.gmsgetb.kpmglinkgo.com/gettaxcalcbac/login/	.profile/
Low	https://qa.gmsgetb.kpmglinkgo.com/	.profile/
Low	https://qa.gmsgetb.kpmglinkgo.com/gettaxcalcbac/	.profile/
Low	https://qa.gmsgetb.kpmglinkgo.com/gettaxcalcbac/login/	.sh_history/
Low	https://qa.gmsgetb.kpmglinkgo.com/gettaxcalcbac/login/	.svn/
Low	https://qa.gmsgetb.kpmglinkgo.com/gettaxcalcbac/	.sh_history/
Low	https://qa.gmsgetb.kpmglinkgo.com/	.sh_history/
Low	https://qa.gmsgetb.kpmglinkgo.com/gettaxcalcbac/	.svn/
Low	https://qa.gmsgetb.kpmglinkgo.com/	.svn/
Low	https://qa.gmsgetb.kpmglinkgo.com/gettaxcalcbac/login/	.bashrc/
Low	https://qa.gmsgetb.kpmglinkgo.com/	.bashrc/
Low	https://qa.gmsgetb.kpmglinkgo.com/gettaxcalcbac/	.bashrc/
Low	https://qa.gmsgetb.kpmglinkgo.com/gettaxcalcbac/login/	.git/
Low	https://qa.gmsgetb.kpmglinkgo.com/	.git/
Low	https://qa.gmsgetb.kpmglinkgo.com/gettaxcalcbac/login/	.mysql_history/
Low	https://qa.gmsgetb.kpmglinkgo.com/gettaxcalcbac/	.git/
Low	https://qa.gmsgetb.kpmglinkgo.com/gettaxcalcbac/	.mysql_history/

Web Application Source Code Disclosure Pattern Found

Risk:	It is possible to retrieve the source code of server-side scripts, which may expose the application logic and other sensitive information such as usernames and passwords
Cause:	Latest patches or hotfixes for 3rd. party products were not installed Temporary files were left in production environment Debugging information was left by the programmer in web pages
Fix:	Remove source code files from your web-server and apply any relevant patches
CVSS Score:	3.7
CVSS Vector:	AV:N/AC:H/PR:N/UI:N/S:U/C:L/I:N/A:N/E:X/RL:X/RC:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MUI:X/MS:X/MC:X/MI:X/MA:X

Severity	URL	Entity
Low	https://qa.gmsgetb.kpmglinkgo.com/gettaxcalcbac/javascript/appMaster.js	appMaster.js

Cookie with SameSite attribute not Restrictive

Risk: Prevent cookie information leakage by restricting cookies to first-party or same-site context to Strict.

Cause: Sensitive Cookie with unrestricted SameSite Attribute

Fix: Review possible solutions for configuring SameSite Cookie attribute to recommended values

CVSS Score: 0.0

CVSS Vector: AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:N/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MUI:X/MS:X/MC:X/MI:X/MA:X

Severity	URL	Entity
Informational	https://qa.gmsgetb.kpmglinkgo.com/	TC-BAC-DEV

Email Address Pattern Found

Risk: It is possible to gather sensitive information about the web application such as usernames, passwords, machine name and/or sensitive file locations

Cause: Insecure web application programming or configuration

Fix: Remove e-mail addresses from the website

CVSS Score: 0.0

CVSS Vector: AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:N/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MUI:X/MS:X/MC:X/MI:X/MA:X

Severity	URL	Entity
Informational	https://qa.gmsgetb.kpmglinkgo.com/gettaxcalcbac/javascript/fingerprint2.js	fingerprint2.js

Missing "Referrer policy" Security Header

Risk: It is possible to gather sensitive information about the web application such as usernames, passwords, machine name and/or sensitive file locations
It is possible to persuade a naive user to supply sensitive information such as username, password, credit card number, social security number etc.

Cause: Insecure web application programming or configuration

Fix: Config your server to use the "Referrer Policy" header with secure policies

CVSS Score: 0.0

CVSS Vector: AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:N/E:X/RL:O/RC:C/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MUI:X/MS:X/MC:X/MI:X/MA:X

Severity	URL	Entity
Informational	https://qa.gmsgetb.kpmglinkgo.com/	qa.gmsgetb.kpmglinkgo.com

A2 - Cryptographic Failures 0

H A3 - Injection 22

Blind LDAP Injection

Risk: It is possible to gather sensitive information about the web application such as usernames, passwords, machine name and/or sensitive file locations
It may be possible to bypass the web application's authentication mechanism

Cause: Sanitation of hazardous characters was not performed correctly on user input

Fix: Review possible solutions for hazardous character injection

CVSS Score: 8.6

CVSS Vector: AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:L/A:L/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MJI:X/MS:X/MC:X/MI:X/MA:X

Severity	URL	Entity
High	https://qa.gmsgetb.kpmglinkgo.com/gettaxcalcbac/login/index/	txtAdditionalArg
High	https://qa.gmsgetb.kpmglinkgo.com/gettaxcalcbac/Home/QuickSearch	userLogin

Inline script execution allowed in CSP

Risk: It is possible to gather sensitive information about the web application such as usernames, passwords, machine name and/or sensitive file locations
It is possible to persuade a naive user to supply sensitive information such as username, password, credit card number, social security number etc.

Cause: Insecure web application programming or configuration

Fix: Configure Content-Security-Policy with proper values

CVSS Score: 8.2

CVSS Vector: AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:L/A:N/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MJI:X/MS:X/MC:X/MI:X/MA:X

Severity	URL	Entity
High	https://qa.gmsgetb.kpmglinkgo.com/gettaxcalcbac/javascript/target/	target[

Required directives missing from the CSP

Risk: It is possible to gather sensitive information about the web application such as usernames, passwords, machine name and/or sensitive file locations
It is possible to persuade a naive user to supply sensitive information such as username, password, credit card number, social security number etc.

Cause: Insecure web application programming or configuration

Fix: Configure Content-Security-Policy with proper values

CVSS Score: 8.2

CVSS Vector: AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:L/A:N/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MJI:X/MS:X/MC:X/MI:X/MA:X

Severity	URL	Entity
High	https://qa.gmsgetb.kpmglinkgo.com/gettaxcalcbac/login/enter	enter
High	https://qa.gmsgetb.kpmglinkgo.com/gettaxcalcbac/login/index/	
High	https://qa.gmsgetb.kpmglinkgo.com/gettaxcalcbac/Home/QuickSearch	QuickSearch
High	https://qa.gmsgetb.kpmglinkgo.com/gettaxcalcbac/	
High	https://qa.gmsgetb.kpmglinkgo.com/gettaxcalcbac/javascript/target/	target[
High	https://qa.gmsgetb.kpmglinkgo.com/gettaxcalcbac/SiteException	SiteException

Missing "Content-Security-Policy" header

Risk: It is possible to gather sensitive information about the web application such as usernames, passwords, machine name and/or sensitive file locations
It is possible to persuade a naive user to supply sensitive information such as username, password, credit card number, social security number etc.

Cause: Insecure web application programming or configuration

Fix: Config your server to use the "Content-Security-Policy" header with secure policies

CVSS Score: 3.7

CVSS Vector: AV:N/AC:H/PR:N/UI:N/S:U/C:L/I:N/A/N/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MUI:X/MS:X/MC:X/MI:X/MA:X

Severity	URL	Entity
Low	https://qa.gmsgetb.kpmglinkgo.com/	qa.gmsgetb.kpmglinkgo.com

Trusted types in scripts not enforced in CSP

Risk: It is possible to gather sensitive information about the web application such as usernames, passwords, machine name and/or sensitive file locations
It is possible to persuade a naive user to supply sensitive information such as username, password, credit card number, social security number etc.

Cause: Insecure web application programming or configuration

Fix: Configure Content-Security-Policy with proper values

CVSS Score: 3.7

CVSS Vector: AV:N/AC:H/PR:N/UI:N/S:U/C:L/I:N/A/N/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MUI:X/MS:X/MC:X/MI:X/MA:X

Severity	URL	Entity
Low	https://qa.gmsgetb.kpmglinkgo.com/gettaxcalcbac/login/enter	enter
Low	https://qa.gmsgetb.kpmglinkgo.com/gettaxcalcbac/login/index/	
Low	https://qa.gmsgetb.kpmglinkgo.com/gettaxcalcbac/javascript/target[	target[
Low	https://qa.gmsgetb.kpmglinkgo.com/gettaxcalcbac/Home/QuickSearch	QuickSearch
Low	https://qa.gmsgetb.kpmglinkgo.com/gettaxcalcbac/SiteException	SiteException
Low	https://qa.gmsgetb.kpmglinkgo.com/gettaxcalcbac/	

Directives ignored by browsers found in CSP

Risk: It is possible to gather sensitive information about the web application such as usernames, passwords, machine name and/or sensitive file locations
It is possible to persuade a naive user to supply sensitive information such as username, password, credit card number, social security number etc.

Cause: Insecure web application programming or configuration

Fix: Configure Content-Security-Policy with proper values

CVSS Score: 0.0

CVSS Vector: AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A/N/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MUI:X/MS:X/MC:X/MI:X/MA:X

Severity	URL	Entity
Informational	https://qa.gmsgetb.kpmglinkgo.com/gettaxcalcbac/login/enter	enter
Informational	https://qa.gmsgetb.kpmglinkgo.com/gettaxcalcbac/login/index/	
Informational	https://qa.gmsgetb.kpmglinkgo.com/gettaxcalcbac/Home/QuickSearch	QuickSearch
Informational	https://qa.gmsgetb.kpmglinkgo.com/gettaxcalcbac/	
Informational	https://qa.gmsgetb.kpmglinkgo.com/gettaxcalcbac/javascript/target[	target[
Informational	https://qa.gmsgetb.kpmglinkgo.com/gettaxcalcbac/SiteException	SiteException

Inline script execution allowed in CSP

Risk: It is possible to gather sensitive information about the web application such as usernames, passwords, machine name and/or sensitive file locations
It is possible to persuade a naive user to supply sensitive information such as username, password, credit card number, social security number etc.

Cause: Insecure web application programming or configuration

Fix: Configure Content-Security-Policy with proper values

CVSS Score: 8.2

CVSS Vector: [AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:L/A:N/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MJI:X/MS:X/MC:X/MI:X/MA:X](#)

Severity	URL	Entity
High	https://qa.gmsgetb.kpmglinkgo.com/gettaxcalcbac/javascript/target	target

Required directives missing from the CSP

Risk: It is possible to gather sensitive information about the web application such as usernames, passwords, machine name and/or sensitive file locations
It is possible to persuade a naive user to supply sensitive information such as username, password, credit card number, social security number etc.

Cause: Insecure web application programming or configuration

Fix: Configure Content-Security-Policy with proper values

CVSS Score: 8.2

CVSS Vector: [AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:L/A:N/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MJI:X/MS:X/MC:X/MI:X/MA:X](#)

Severity	URL	Entity
High	https://qa.gmsgetb.kpmglinkgo.com/gettaxcalcbac/login/enter	enter
High	https://qa.gmsgetb.kpmglinkgo.com/gettaxcalcbac/login/index/	
High	https://qa.gmsgetb.kpmglinkgo.com/gettaxcalcbac/Home/QuickSearch	QuickSearch
High	https://qa.gmsgetb.kpmglinkgo.com/gettaxcalcbac/	
High	https://qa.gmsgetb.kpmglinkgo.com/gettaxcalcbac/javascript/target	target
High	https://qa.gmsgetb.kpmglinkgo.com/gettaxcalcbac/SiteException	SiteException

Cacheable SSL Page Found

Risk: It is possible to gather sensitive information about the web application such as usernames, passwords, machine name and/or sensitive file locations

Cause: Sensitive information might have been cached by your browser

Fix: Prevent caching of SSL pages by adding "Cache-Control: no-store" and "Pragma: no-cache" headers to their responses.

CVSS Score: 3.7

CVSS Vector: AV:N/AC:H/PR:NU/I:N/S:U/C:L/I:N/A:N/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MUI:X/MS:X/MC:X/MI:X/MA:X

Severity	URL	Entity
Low	https://qa.gmsgetb.kpmglinkgo.com/gettaxcalcbac/javascript/calendar-setup.js	calendar-setup.js
Low	https://qa.gmsgetb.kpmglinkgo.com/gettaxcalcbac/javascript/calendar.js	calendar.js
Low	https://qa.gmsgetb.kpmglinkgo.com/gettaxcalcbac/javascript/navResizer.js	navResizer.js
Low	https://qa.gmsgetb.kpmglinkgo.com/gettaxcalcbac/javascript/backgroundtasks.js	backgroundtasks.js
Low	https://qa.gmsgetb.kpmglinkgo.com/gettaxcalcbac/javascript/commonFunctions.js	commonFunctions.js
Low	https://qa.gmsgetb.kpmglinkgo.com/gettaxcalcbac/javascript/site.js	site.js
Low	https://qa.gmsgetb.kpmglinkgo.com/gettaxcalcbac/javascript/popupWindow.js	popupWindow.js
Low	https://qa.gmsgetb.kpmglinkgo.com/gettaxcalcbac/javascript/views/help.js	help.js
Low	https://qa.gmsgetb.kpmglinkgo.com/gettaxcalcbac/javascript/views/auditLog.js	auditLog.js
Low	https://qa.gmsgetb.kpmglinkgo.com/gettaxcalcbac/javascript/views/adminVariable.js	adminVariable.js
Low	https://qa.gmsgetb.kpmglinkgo.com/gettaxcalcbac/javascript/locationUtils.js	locationUtils.js
Low	https://qa.gmsgetb.kpmglinkgo.com/gettaxcalcbac/javascript/appMaster.js	appMaster.js

Missing "Content-Security-Policy" header

Risk: It is possible to gather sensitive information about the web application such as usernames, passwords, machine name and/or sensitive file locations
It is possible to persuade a naive user to supply sensitive information such as username, password, credit card number, social security number etc.

Cause: Insecure web application programming or configuration

Fix: Config your server to use the "Content-Security-Policy" header with secure policies

CVSS Score: 3.7

CVSS Vector: AV:N/AC:H/PR:NU/I:N/S:U/C:L/I:N/A:N/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MUI:X/MS:X/MC:X/MI:X/MA:X

Severity	URL	Entity
Low	https://qa.gmsgetb.kpmglinkgo.com/	qa.gmsgetb.kpmglinkgo.com

Trusted types in scripts not enforced in CSP

Risk: It is possible to gather sensitive information about the web application such as usernames, passwords, machine name and/or sensitive file locations
It is possible to persuade a naive user to supply sensitive information such as username, password, credit card number, social security number etc.

Cause: Insecure web application programming or configuration

Fix: Configure Content-Security-Policy with proper values

CVSS Score: 3.7

CVSS Vector: AV:N/AC:H/PR:N/UI:N/S:U/C:L/I:N/A:N/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MUI:X/MS:X/MC:X/MI:X/MA:X

Severity	URL	Entity
Low	https://qa.gmsgetb.kpmglinkgo.com/gettaxcalcbac/login/enter	enter
Low	https://qa.gmsgetb.kpmglinkgo.com/gettaxcalcbac/login/index/	
Low	https://qa.gmsgetb.kpmglinkgo.com/gettaxcalcbac/javascript/target[	target[
Low	https://qa.gmsgetb.kpmglinkgo.com/gettaxcalcbac/Home/QuickSearch	QuickSearch
Low	https://qa.gmsgetb.kpmglinkgo.com/gettaxcalcbac/SiteException	SiteException
Low	https://qa.gmsgetb.kpmglinkgo.com/gettaxcalcbac/	

Directives ignored by browsers found in CSP

Risk: It is possible to gather sensitive information about the web application such as usernames, passwords, machine name and/or sensitive file locations
It is possible to persuade a naive user to supply sensitive information such as username, password, credit card number, social security number etc.

Cause: Insecure web application programming or configuration

Fix: Configure Content-Security-Policy with proper values

CVSS Score: 0.0

CVSS Vector: AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:N/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MUI:X/MS:X/MC:X/MI:X/MA:X

Severity	URL	Entity
Informational	https://qa.gmsgetb.kpmglinkgo.com/gettaxcalcbac/login/enter	enter
Informational	https://qa.gmsgetb.kpmglinkgo.com/gettaxcalcbac/login/index/	
Informational	https://qa.gmsgetb.kpmglinkgo.com/gettaxcalcbac/Home/QuickSearch	QuickSearch
Informational	https://qa.gmsgetb.kpmglinkgo.com/gettaxcalcbac/	
Informational	https://qa.gmsgetb.kpmglinkgo.com/gettaxcalcbac/javascript/target[	target[
Informational	https://qa.gmsgetb.kpmglinkgo.com/gettaxcalcbac/SiteException	SiteException

Email Address Pattern Found

Risk: It is possible to gather sensitive information about the web application such as usernames, passwords, machine name and/or sensitive file locations

Cause: Insecure web application programming or configuration

Fix: Remove e-mail addresses from the website

CVSS Score: 0.0

CVSS Vector: AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:N/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MUI:X/MS:X/MC:X/MI:X/MA:X

Severity	URL	Entity
Informational	https://qa.gmsgetb.kpmglinkgo.com/gettaxcalcbac/javascript/fingerprint2.js	fingerprint2.js

Inline script execution allowed in CSP

Risk: It is possible to gather sensitive information about the web application such as usernames, passwords, machine name and/or sensitive file locations
It is possible to persuade a naive user to supply sensitive information such as username, password, credit card number, social security number etc.

Cause: Insecure web application programming or configuration

Fix: Configure Content-Security-Policy with proper values

CVSS Score: 8.2

CVSS Vector: [AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:L/A:N/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MUI:X/MS:X/MC:X/MI:X/MA:X](#)

Severity	URL	Entity
High	https://qa.gmsgetb.kpmglinkgo.com/gettaxcalcbac/javascript/target[	target[

Required directives missing from the CSP

Risk: It is possible to gather sensitive information about the web application such as usernames, passwords, machine name and/or sensitive file locations
It is possible to persuade a naive user to supply sensitive information such as username, password, credit card number, social security number etc.

Cause: Insecure web application programming or configuration

Fix: Configure Content-Security-Policy with proper values

CVSS Score: 8.2

CVSS Vector: [AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:L/A:N/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MUI:X/MS:X/MC:X/MI:X/MA:X](#)

Severity	URL	Entity
High	https://qa.gmsgetb.kpmglinkgo.com/gettaxcalcbac/login/enter	enter
High	https://qa.gmsgetb.kpmglinkgo.com/gettaxcalcbac/login/index/	
High	https://qa.gmsgetb.kpmglinkgo.com/gettaxcalcbac/Home/QuickSearch	QuickSearch
High	https://qa.gmsgetb.kpmglinkgo.com/gettaxcalcbac/	
High	https://qa.gmsgetb.kpmglinkgo.com/gettaxcalcbac/javascript/target[	target[
High	https://qa.gmsgetb.kpmglinkgo.com/gettaxcalcbac/SiteException	SiteException

Missing "Content-Security-Policy" header

Risk: It is possible to gather sensitive information about the web application such as usernames, passwords, machine name and/or sensitive file locations
It is possible to persuade a naive user to supply sensitive information such as username, password, credit card number, social security number etc.

Cause: Insecure web application programming or configuration

Fix: Config your server to use the "Content-Security-Policy" header with secure policies

CVSS Score: 3.7

CVSS Vector: [AV:N/AC:H/PR:N/UI:N/S:U/C:L/I:N/A:N/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MUI:X/MS:X/MC:X/MI:X/MA:X](#)

Severity	URL	Entity
Low	https://qa.gmsgetb.kpmglinkgo.com/	qa.gmsgetb.kpmglinkgo.com

Trusted types in scripts not enforced in CSP

Risk: It is possible to gather sensitive information about the web application such as usernames, passwords, machine name and/or sensitive file locations
It is possible to persuade a naive user to supply sensitive information such as username, password, credit card number, social security number etc.

Cause: Insecure web application programming or configuration

Fix: Configure Content-Security-Policy with proper values

CVSS Score: 3.7

CVSS Vector: AV:N/AC:H/PR:N/UI:N/S:U/C:L/I:N/A:N/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MUI:X/MS:X/MC:X/MI:X/MA:X

Severity	URL	Entity
Low	https://qa.gmsgetb.kpmglinkgo.com/gettaxcalcbac/login/enter	enter
Low	https://qa.gmsgetb.kpmglinkgo.com/gettaxcalcbac/login/index/	
Low	https://qa.gmsgetb.kpmglinkgo.com/gettaxcalcbac/javascript/target/	target[
Low	https://qa.gmsgetb.kpmglinkgo.com/gettaxcalcbac/Home/QuickSearch	QuickSearch
Low	https://qa.gmsgetb.kpmglinkgo.com/gettaxcalcbac/SiteException	SiteException
Low	https://qa.gmsgetb.kpmglinkgo.com/gettaxcalcbac/	

Directives ignored by browsers found in CSP

Risk: It is possible to gather sensitive information about the web application such as usernames, passwords, machine name and/or sensitive file locations
It is possible to persuade a naive user to supply sensitive information such as username, password, credit card number, social security number etc.

Cause: Insecure web application programming or configuration

Fix: Configure Content-Security-Policy with proper values

CVSS Score: 0.0

CVSS Vector: AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:N/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MUI:X/MS:X/MC:X/MI:X/MA:X

Severity	URL	Entity
Informational	https://qa.gmsgetb.kpmglinkgo.com/gettaxcalcbac/login/enter	enter
Informational	https://qa.gmsgetb.kpmglinkgo.com/gettaxcalcbac/login/index/	
Informational	https://qa.gmsgetb.kpmglinkgo.com/gettaxcalcbac/Home/QuickSearch	QuickSearch
Informational	https://qa.gmsgetb.kpmglinkgo.com/gettaxcalcbac/	
Informational	https://qa.gmsgetb.kpmglinkgo.com/gettaxcalcbac/javascript/target/	target[
Informational	https://qa.gmsgetb.kpmglinkgo.com/gettaxcalcbac/SiteException	SiteException

A6 - Vulnerable and Outdated Components 0

A7 - Identification and Authentication Failures 0

H A8 - Software and Data Integrity Failures 20

Inline script execution allowed in CSP

Risk: It is possible to gather sensitive information about the web application such as usernames, passwords, machine name and/or sensitive file locations
It is possible to persuade a naive user to supply sensitive information such as username, password, credit card number, social security number etc.

Cause: Insecure web application programming or configuration

Fix: Configure Content-Security-Policy with proper values

CVSS Score: 8.2

CVSS Vector: [AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:L/A:N/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MUI:X/MS:X/MC:X/MI:X/MA:X](#)

Severity	URL	Entity
High	https://qa.gmsgetb.kpmglinkgo.com/gettaxcalcbac/javascript/target[	target[

Required directives missing from the CSP

Risk: It is possible to gather sensitive information about the web application such as usernames, passwords, machine name and/or sensitive file locations
It is possible to persuade a naive user to supply sensitive information such as username, password, credit card number, social security number etc.

Cause: Insecure web application programming or configuration

Fix: Configure Content-Security-Policy with proper values

CVSS Score: 8.2

CVSS Vector: [AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:L/A:N/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MUI:X/MS:X/MC:X/MI:X/MA:X](#)

Severity	URL	Entity
High	https://qa.gmsgetb.kpmglinkgo.com/gettaxcalcbac/login/enter	enter
High	https://qa.gmsgetb.kpmglinkgo.com/gettaxcalcbac/login/index/	
High	https://qa.gmsgetb.kpmglinkgo.com/gettaxcalcbac/Home/QuickSearch	QuickSearch
High	https://qa.gmsgetb.kpmglinkgo.com/gettaxcalcbac/	
High	https://qa.gmsgetb.kpmglinkgo.com/gettaxcalcbac/javascript/target[	target[
High	https://qa.gmsgetb.kpmglinkgo.com/gettaxcalcbac/SiteException	SiteException

Missing "Content-Security-Policy" header

Risk: It is possible to gather sensitive information about the web application such as usernames, passwords, machine name and/or sensitive file locations
It is possible to persuade a naive user to supply sensitive information such as username, password, credit card number, social security number etc.

Cause: Insecure web application programming or configuration

Fix: Config your server to use the "Content-Security-Policy" header with secure policies

CVSS Score: 3.7

CVSS Vector: [AV:N/AC:H/PR:N/UI:N/S:U/C:L/I:N/A:N/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MUI:X/MS:X/MC:X/MI:X/MA:X](#)

Severity	URL	Entity
Low	https://qa.gmsgetb.kpmglinkgo.com/	qa.gmsgetb.kpmglinkgo.com

Trusted types in scripts not enforced in CSP

Risk: It is possible to gather sensitive information about the web application such as usernames, passwords, machine name and/or sensitive file locations
It is possible to persuade a naive user to supply sensitive information such as username, password, credit card number, social security number etc.

Cause: Insecure web application programming or configuration

Fix: Configure Content-Security-Policy with proper values

CVSS Score: 3.7

CVSS Vector: AV:N/AC:H/PR:N/UI:N/S:U/C:L/I:N/A:N/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MUI:X/MS:X/MC:X/M:X/MA:X

Severity	URL	Entity
Low	https://qa.gmsgetb.kpmglinkgo.com/gettaxcalcbac/login/enter	enter
Low	https://qa.gmsgetb.kpmglinkgo.com/gettaxcalcbac/login/index/	
Low	https://qa.gmsgetb.kpmglinkgo.com/gettaxcalcbac/javascript/target/	target[
Low	https://qa.gmsgetb.kpmglinkgo.com/gettaxcalcbac/Home/QuickSearch	QuickSearch
Low	https://qa.gmsgetb.kpmglinkgo.com/gettaxcalcbac/SiteException	SiteException
Low	https://qa.gmsgetb.kpmglinkgo.com/gettaxcalcbac/	

Directives ignored by browsers found in CSP

Risk: It is possible to gather sensitive information about the web application such as usernames, passwords, machine name and/or sensitive file locations
It is possible to persuade a naive user to supply sensitive information such as username, password, credit card number, social security number etc.

Cause: Insecure web application programming or configuration

Fix: Configure Content-Security-Policy with proper values

CVSS Score: 0.0

CVSS Vector: AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:N/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MUI:X/MS:X/MC:X/M:X/MA:X

Severity	URL	Entity
Informational	https://qa.gmsgetb.kpmglinkgo.com/gettaxcalcbac/login/enter	enter
Informational	https://qa.gmsgetb.kpmglinkgo.com/gettaxcalcbac/login/index/	
Informational	https://qa.gmsgetb.kpmglinkgo.com/gettaxcalcbac/Home/QuickSearch	QuickSearch
Informational	https://qa.gmsgetb.kpmglinkgo.com/gettaxcalcbac/	
Informational	https://qa.gmsgetb.kpmglinkgo.com/gettaxcalcbac/javascript/target/	target[
Informational	https://qa.gmsgetb.kpmglinkgo.com/gettaxcalcbac/SiteException	SiteException

A9 - Security Logging and Monitoring Failures 0

A10 - Server-Side Request Forgery (SSRF) 0

How to Fix

Blind LDAP Injection

Cause:

Sanitation of hazardous characters was not performed correctly on user input

Risk:

It is possible to gather sensitive information about the web application such as usernames, passwords, machine name and/or sensitive file locations

It may be possible to bypass the web application's authentication mechanism

The software constructs all or part of an LDAP query using externally-influenced input, and fails to neutralize elements that could be used to modify the LDAP query.

Without sufficient removal or quoting of LDAP syntax in user-controllable inputs, the generated LDAP query can cause those inputs to be interpreted as LDAP instead of ordinary user data. This can be used to alter query logic to bypass security checks, or to insert additional statements that modify the back-end database, possibly including execution of system commands.

Blind LDAP Injection is similar to LDAP Injection. The difference lies in the fact that to leverage it, the attacker does not need to look for LDAP errors in the response. Therefore, the method AppScan uses to identify it is also different.

Instead of attempting to invoke an LDAP error, AppScan locates scripts that are susceptible to LDAP injection, by manipulating the logic of the application through multiple requests.

The technique calls for sending requests whose vulnerable parameter (the parameter that gets embedded in the LDAP query) is modified so that the response indicates whether the data is used in an LDAP query context or not. The modification involves the use of an AND Boolean expression with the original query which evaluates once as True and once as False. In one case, the net result should be identical to the original result (a successful login), and in the other case, the result should be significantly different (a failed login). An OR expression which evaluates as True may also be useful for some rare cases.

Affected Products:

This issue may affect different types of products.

Fix Recommendation:

General

There are several mitigation techniques:

[1] Strategy: Libraries or Frameworks

Use a vetted library or framework that does not allow this weakness or provides constructs that make it easier to avoid.

[2] Strategy: Parameterization

If available, use structured mechanisms that automatically enforce separation between data and code. These mechanisms may be able to provide the relevant quoting, encoding, and validation automatically, instead of relying on the developer to provide this at every point where output is generated.

[3] Strategy: Environment Hardening

Run your code using the lowest privileges that are required to accomplish the necessary tasks.

[4] Strategy: Output Encoding

If you need to use dynamically-generated query strings or commands in spite of the risk, properly quote arguments, and escape any special characters within those arguments.

[5] Strategy: Input Validation

Assume all input is malicious. Use an "accept known good" input validation strategy: a whitelist of acceptable inputs that strictly conform to specifications. Reject any input that does not strictly conform to specifications, or transform it into something that does. Do not rely exclusively on detecting for malicious or malformed inputs with a blacklist. However, blacklists can be useful for detecting potential attacks or determining which inputs are so malformed that they should be rejected outright.

CWE:

90
707
943
74
20

External References:

[LDAP Resources](#)
[LDAP RFC](#)

Inline script execution allowed in CSP

Cause:

Insecure web application programming or configuration

Risk:

The "Content-Security-Policy" header is designed to modify the way browsers render pages, and thus to protect from various cross-site injections, including Cross-Site Scripting. It is important to set the header value correctly, in a way that will not prevent proper operation of the web site. Allowing inline scripts can expose the site to XSS attacks, as a result, attackers can inject malicious scripts.

Affected Products:

This issue may affect different types of products

Fix Recommendation:

General

script-src directive contains 'unsafe-inline' which allows the execution of unsafe inline scripts. Remove 'unsafe-inline' from your script-src directive and use nonces or hashes to allow specific inline scripts.

CWE:

1032
79
693
830
1021

External References:

[MDN web docs - Content-Security-Policy](#)

Required directives missing from the CSP

Cause:

Insecure web application programming or configuration

Risk:

The "Content-Security-Policy" header is designed to modify the way browsers render pages, and thus to protect from various cross-site injections, including Cross-Site Scripting. It is important to set the header value correctly, in a way that will not prevent proper operation of the web site. Missing essential directives can leave a site vulnerable, as a result, attack vectors like XSS could be exploited.

Affected Products:

This issue may affect different types of products

Fix Recommendation:

General

One or more of the following directives are missing: script-src, object-src, base-uri. Add the missing directive[s] to your CSP to mitigate injection risks. object-src should be set to 'none', base-uri should be set to 'none' or 'self'.

CWE:

1032
79
693
830
1021

External References:

[MDN web docs - Content-Security-Policy](#)

Cookie with Insecure or Improper or Missing SameSite attribute

Cause:

Sensitive Cookie with Improper or Insecure or Missing SameSite Attribute

Risk:

Prevent Cookie information leakage by restricting cookies to first-party or same-site context

Attacks can extend to Cross-Site-Request-Forgery (CSRF) attacks if there are no additional protections in place (such as Anti-CSRF tokens).

The SameSite attribute controls how cookies are sent for cross-domain requests.

The attribute may have three values: 'Lax', 'Strict', or 'None'. If 'None' is used, a website may create a cross-domain POST HTTP request to another website, and the browser automatically adds cookies to this request.

This may lead to Cross-Site-Request-Forgery (CSRF) attacks if there are no additional protections in place (such as Anti-CSRF tokens).

Modes and their uses:

'Lax' mode: the cookie will only be sent with a top-level get request.

'Strict' mode; the cookie will not be sent with any cross-site usage even if the user follows a link to another website.

'None' mode: the cookie will be sent with the cross-site requests.

The attribute having: 'Lax' or 'None' must have 'Secure' Flag set and must be transferred over https.

Example - Set-Cookie: key=value; SameSite=Lax; Secure

Setting attribute to 'Strict' is the recommended option.

Example - Set-Cookie: key=value; SameSite=Strict

Affected Products:

This issue may affect different types of products.

Fix Recommendation:

General

[1] Review possible solutions for configuring SameSite Cookie attribute to recommended values.

[2] Restrict Cookies to a first-party or same-site context.

[3] Verify and set the SameSite attribute of your cookie to Strict, to ensure that the cookie will only be sent in a first-party context.

[4] Or, if you want to relax the restrictions of first-party context, then verify and set the SameSite attribute of the cookie to Lax with Secure Flag enabled and transferred over HTTPS.

CWE:

1275

284

923

External References:

[WASC Threat Classification: Information Leakage](#)

[SameSite Cookies](#)

Missing or insecure Cross-Origin-Embedder-Policy (COEP) header

Cause:

Insecure web application programming or configuration

Risk:

Embedding cross-origin resources like scripts or images without restrictions makes your site vulnerable to untrusted code execution and side-channel leaks. An attacker can include opaque third-party resources that don't use proper CORS headers, creating security holes even without direct script execution. This attack vector relies on silently pulling in third-party resources that bypass validation.

Without COEP, attackers can embed untrusted resources that bypass CORS enforcement, opening the door to data leaks and breaking cross-origin isolation required for secure APIs.

Affected Products:

This issue may affect different types of products.

Fix Recommendation:

General

Set the header "Cross-Origin-Embedder-Policy: require-corp" to enforce that only CORS-enabled or same-origin resources can be loaded.

CWE:

200

External References:

[OWASP Secure Headers Project - COEP](#)

Missing or insecure Cross-Origin-Opener-Policy (COOP) header

Cause:

Insecure web application programming or configuration

Risk:

Modern browsers allow windows and tabs to interact if they open each other, even when from different origins. This behavior can expose your site to cross-origin side-channel attacks, by allowing malicious sites to share a browsing context with yours. The attack vector involves the attacker opening your site in a new tab or iframe, and using shared references like 'window.opener'.

Without COOP, a malicious site can open your page in a new tab and exploit shared browsing context to perform side-channel attacks, potentially leaking cross-origin data like session tokens or sensitive content.

Affected Products:

This issue may affect different types of products.

Fix Recommendation:

General

Set the header "Cross-Origin-Opener-Policy: same-origin" to ensure your site runs in a separate browsing context group, isolating it from other origins.

CWE:

200

External References:

[OWASP Secure Headers Project - COOP](#)

Missing or insecure Cross-Origin-Resource-Policy (CORP) header

Cause:

Insecure web application programming or configuration

Risk:

Web applications often serve static resources like images, scripts, or APIs that aren't meant to be embedded or reused by other websites. Without protection, a malicious site can embed your resources and extract sensitive data, sometimes using timing attacks or leaking metadata via browser behavior. This happens when resources are not protected and are freely accessible cross-origin.

Without CORP, third-party sites can embed and misuse your private resources, enabling data leaks or piggybacking on authenticated sessions.

Affected Products:

This issue may affect different types of products.

Fix Recommendation:

General

Set the "Cross-Origin-Resource-Policy" header on resources to "same-origin" or "same-site" to prevent unauthorized embedding or reuse by third parties.

CWE:

200

External References:

[OWASP Secure Headers Project - CORP](#)

Body Parameters Accepted in Query

Cause:

Insecure web application programming or configuration

Risk:

It is possible to gather sensitive information about the web application such as usernames, passwords, machine name and/or sensitive file locations

It is possible to persuade a naive user to supply sensitive information such as username, password, credit card number, social security number etc.

GET requests are designed to query the server, while POST requests are for submitting data.

However, aside from the technical purpose, attacking query parameters is easier than body parameters, because sending a link to the original site, or posting it in a blog or comment, is easier and has better results than the alternative - in order to attack a request with body parameters, an attacker would need to create a page containing a form that will be submitted when visited by the victim.

It is a lot harder to convince the victim to visit a page that he doesn't know, than letting him visit the original site. It is therefore not recommended to support body parameters that arrive in the query string.

Affected Products:

This issue may affect different types of products.

Fix Recommendation:

General

Re-program the application to disallow handling of POST parameters that were listed in the Query

CWE:

200

693

External References:

[GET](#)
[POST](#)

Cacheable SSL Page Found

Cause:

Sensitive information might have been cached by your browser

Risk:

It is possible to gather sensitive information about the web application such as usernames, passwords, machine name and/or sensitive file locations. Most web browsers are configured by default to cache the user's pages during use. This means that SSL pages are cached as well. It is not recommended to enable the web browser to save any SSL information, since this information might be compromised when a vulnerability exists.

Affected Products:

This issue may affect different types of products.

Fix Recommendation:

General

Disable caching on all SSL pages or all pages that contain sensitive data.

This can be achieved by using "Cache-Control: no-store" and either "Pragma: no-cache" or "Cache-Control: no-cache" response directives in your SSL page headers.

Cache-Control: private - This directive instructs proxies that the page contains private information, and therefore should not be cached by a shared cache. However, it does not instruct browsers to refrain from caching the pages.

Cache-Control: no-cache - This directive also instructs proxies that the page contains private information, and therefore should not be cached. It also instructs the browser to revalidate with the server to check if a new version is available. This means that the browser may store sensitive pages or information to be used in the revalidation. Certain browsers do not necessarily follow the RFC and may treat no-cache as no-store.

Cache-Control: no-store - This is the most secure directive. It instructs both the proxy and the browser not to cache the page or store it in its cache folders.

Pragma: no-cache - This directive is required for older browsers, that do not support the Cache-Control header.

CWE:

525
524
668
200

Hidden Directory Detected

Cause:

The web server or application server are configured in an insecure way

Risk:

It is possible to retrieve information about the site's file system structure, which may help the attacker to map the web site

The web application has exposed the presence of a directory in the site. Although the directory does not list its content, the information may help an attacker to develop further attacks against the site. For example, by knowing the directory name, an attacker can guess its content type and possibly file names that reside in it, or sub directories under it, and try to access them.

The more sensitive the content is, the more severe this issue may be.

Affected Products:

This issue may affect different types of products.

Fix Recommendation:

General

If the forbidden resource is not required, remove it from the site.

If possible, issue a "404 - Not Found" response status code instead of "403 - Forbidden". This change will obfuscate the presence of the directory in the site, and will prevent the site structure from being exposed.

CWE:

200
497

Missing "Content-Security-Policy" header

Cause:

Insecure web application programming or configuration

Risk:

It is possible to gather sensitive information about the web application such as usernames, passwords, machine name and/or sensitive file locations

It is possible to persuade a naive user to supply sensitive information such as username, password, credit card number, social security number etc.

The absence or improper values of CSP can cause the web application being vulnerable to XSS, clickjacking, etc.

The "Content-Security-Policy" header is designed to modify the way browsers render pages, and thus to protect from various cross-site injections, including Cross-Site Scripting. It is important to set the header value correctly, in a way that will not prevent proper operation of the web site. For example, if the header is set to prevent execution of inline JavaScript, the web site must not use inline JavaScript in its pages.

To protect against Cross-Site Scripting, Cross-Frame Scripting and clickjacking, it is important to set the following policies with proper values:

Both of 'default-src' and 'frame-ancestors' policies, *OR* all of 'script-src', 'object-src' and 'frame-ancestors' policies.

For 'default-src', 'script-src' and 'object-src', insecure values such as '*', 'data:', 'unsafe-inline' or 'unsafe-eval' should be avoided.

For 'frame-ancestors', insecure values such as '*' or 'data:' should be avoided.

Additionally for 'script-src', and 'default-src' (fallback directive for 'script-src') 'self' is considered insecure and should be avoided.

Please refer the following links for more information.

Please note that "Content-Security-Policy" includes four different tests. A general test that verifies if the "Content-Security-Policy" header is being used and three additional tests that check if "Frame-Ancestors", "Object-Src" and "Script-Src" were configured correctly.

Affected Products:

This issue may affect different types of products

Fix Recommendation:

General

Configure your server to send the "Content-Security-Policy" header.

It is recommended to configure Content-Security-Policy header with secure values for its directives as below:

For 'default-src', and 'script-src' secure values such as 'none', or <https://any.example.com>.

For 'frame-ancestors', and 'object-src' secure values such as 'self', 'none' or <https://any.example.com> are expected.

"unsafe-inline" and "unsafe-eval" must not be used in any circumstance. Using nonce / hash would be only considered for short-term workaround.

For Apache, see:

http://httpd.apache.org/docs/2.2/mod/mod_headers.html

For IIS, see:

<https://technet.microsoft.com/pl-pl/library/cc753133%28v=ws.10%29.aspx>

For nginx, see:

http://nginx.org/en/docs/http/nginx_headers_module.html

CWE:

1032

79

693

830

1021

External References:

[List of some secure Headers](#)

[An Introduction to Content Security Policy](#)

[MDN web docs - Content-Security-Policy](#)

Trusted types in scripts not enforced in CSP

Cause:

Insecure web application programming or configuration

Risk:

The "Content-Security-Policy" header is designed to modify the way browsers render pages, and thus to protect from various cross-site injections, including Cross-Site Scripting. It is important to set the header value correctly, in a way that will not prevent proper operation of the web site.

Not using Trusted Types can allow attackers to inject scripts, as a result, this increases the risk of XSS vulnerabilities.

Affected Products:

This issue may affect different types of products

Fix Recommendation:

General

Consider using 'require-trusted-types-for' directive to prevent DOM-based XSS attacks.
Add "require-trusted-types-for 'script'" directive to your CSP to enforce Trusted Types for scripts.

CWE:

1032
79
693
830
1021

External References:

[MDN web docs - Content-Security-Policy](#)

Web Application Source Code Disclosure Pattern Found

Cause:

- Latest patches or hotfixes for 3rd. party products were not installed
- Temporary files were left in production environment
- Debugging information was left by the programmer in web pages

Risk:

It is possible to retrieve the source code of server-side scripts, which may expose the application logic and other sensitive information such as usernames and passwords
AppScan detected a response containing fragments of application source code.
Application source code should not be accessible to web users, as it may contain sensitive application information and back-end logic.
While such leakage does not necessarily represent a breach in security, it can give an attacker useful guidance for future exploitation. Leakage of sensitive information may carry various levels of risk and should be limited whenever possible.

Affected Products:

This issue may affect different types of products.

Fix Recommendation:

General

There are many ways a web application can be coaxed into revealing application source code.
To ensure that your application does not allow web users access to source code:
[1] Check that all system patches related to source code disclosure are installed.
[2] Check that no application source code is left in HTML comments.
[3] Check that all source code files are removed from the production environment.

CWE:

540
200

Cookie with SameSite attribute not Restrictive

Cause:

Sensitive Cookie with Unrestrictive SameSite Attributes and Flags

Risk:

Prevent Cookie information leakage by restricting cookies to first-party or same-site context as Strict

Attacks can extend to Cross-Site-Request-Forgery (CSRF) attacks if there are no additional protections in place (such as Anti-CSRF tokens).

The SameSite attribute controls how cookies are sent for cross-domain requests.

* Strict mode is recommended, the cookie will not be sent with any cross-site usage even if the user follows a link to another website.

* Setting SameSite attribute to 'Strict' will only be sent in a first-party context and not be sent along with requests initiated by third party websites.

* Example - Set-Cookie: key=value; SameSite=Strict

Affected Products:

This issue may affect different types of products.

Fix Recommendation:

General

[1] Restrict Cookies to a first-party context.

[2] Verify and set the SameSite attribute of the cookie to Strict, to ensure that the cookie will only be sent in a first-party context.

[3] The value "Lax" will suffice if you avoid using GET requests, and a good session management mechanism is in place to mitigate the risk of CSRF completely.

CWE:

1275

923

284

External References:

WASC Threat Classification: Information Leakage

SameSite Cookies

Directives ignored by browsers found in CSP

Cause:

Insecure web application programming or configuration

Risk:

The "Content-Security-Policy" header is designed to modify the way browsers render pages, and thus to protect from various cross-site injections, including Cross-Site Scripting. It is important to set the header value correctly, in a way that will not prevent proper operation of the web site.

Some directives (unsupported, invalid, deprecated, etc.) might be ignored by browsers, leading to misconfigurations, as a result, security policies may not function as intended.

Affected Products:

This issue may affect different types of products

Fix Recommendation:

General

Remove any ignored value from your CSP:

* In CSP2 and above, when a nonce or a hash is present, 'unsafe-inline' is ignored.

* In CSP3 and above, when 'strict-dynamic' is present, any host-source or scheme-source is ignored (e.g. 'self', http[s]://, https://example.com, etc).

CWE:

1032

79

693

830

1021

External References:

MDN web docs - Content-Security-Policy

Email Address Pattern Found

Cause:

Insecure web application programming or configuration

Risk:

It is possible to gather sensitive information about the web application such as usernames, passwords, machine name and/or sensitive file locations. Spambots crawl internet sites, set out to find e-mail addresses in order to build mailing lists for sending unsolicited e-mail (spam). AppScan detected a response containing one or more e-mail addresses, which may be exploited to send spam mail. Furthermore, the e-mail addresses found may be private and thus should not be accessible to the general public.

Affected Products:

This issue may affect different types of products.

Fix Recommendation:

General

Remove any e-mail addresses from the website so that they won't be exploited by malicious users.

CWE:

359
200
311

External References:

[Definition of Spambot \(Wikipedia\)](#)

Missing "Referrer policy" Security Header

Cause:

Insecure web application programming or configuration

Risk:

It is possible to gather sensitive information about the web application such as usernames, passwords, machine name and/or sensitive file locations. It is possible to persuade a naive user to supply sensitive information such as username, password, credit card number, social security number etc. The absence or improper values of Referrer Policy can cause URL leak itself, and even sensitive information contained in the URL will be leaked to the cross-site. This is a part of ruleset to check if Referrer Policy is present and if so to test its configuration. The "Referer Policy" header defines what data is made available in the Referer header, and for navigation and iframes in the destination's (document.referrer). This header is designed to modify the way browsers render pages, and thus to prevent cross-domain Referer leakage. It is important to set the header value correctly, in a way that will not prevent proper operation of the web site. Referer header is a request header that indicates the site which the traffic originated from. If there is no adequate prevention in place, the URL itself, and even sensitive information contained in the URL will be leaked to the cross-site. "no-referrer-when-downgrade" and "unsafe-url" are the policies which leak the Full Url for the ThirdParty Sites. The remaining policies are "no-referrer", "origin", "origin-when-cross-origin", "same-origin", "strict-origin", "strict-origin-when-cross-origin". Please refer the following links for more information.

Affected Products:

This issue may affect different types of products

Fix Recommendation:

General

Configure your server to send the "Referrer Policy" header.

It is recommended to configure Referrer Policy header with secure values for its directives as below:

"strict-origin-when-cross-origin" offers more privacy. With this policy, only the origin is sent in the Referer header of cross-origin requests.

For Google Chrome, see:

<https://developers.google.com/web/updates/2020/07/referrer-policy-new-chrome-default>

For Firefox, see:

<https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Referrer-Policy>.

CWE:

200

664

668

External References:

[MDN web docs - Referrer-Policy](#)